Práctica 1: Recogida de información pasiva

Técnicas de Hacking - UEM

Estudiante: Gonzalo Revuelta
Objetivo: Repsol S.A. (Empresa IBEX 35)

Índice

Práctica 1: Recogida de información pasiva 1
Técnicas de Hacking - UEM 1
Resumen 2
Introducción 2
Desarrollo 2
1. Investigación de Registros DNS 2
2. Perfilado de Repsol S.A. 2
Resultados 2
Análisis de Infraestructura 2
Google Dorking (Fuga de Información) 3
Conclusiones 5
Bibliografía 6

Resumen

Este informe presenta los resultados de una auditoría de reconocimiento pasivo sobre Repsol S.A. Se ha recopilado información sobre su infraestructura tecnológica y presencia digital utilizando fuentes abiertas (OSINT). El análisis permite identificar posibles vectores de ataque sin interactuar directamente con los sistemas de la compañía, garantizando el anonimato del auditor.

Introducción

La recogida de información es la fase crítica que determina el éxito de una auditoría de ciberseguridad. En este documento se aborda primero la base teórica de los registros DNS y su relevancia, para posteriormente aplicar dicho conocimiento en un caso real sobre una empresa del IBEX 35, analizando su huella digital y posibles fugas de información.

Desarrollo

1. Investigación de Registros DNS

El DNS no solo traduce nombres a IPs, sino que almacena metadatos clave para el reconocimiento. A continuación, se describen los registros solicitados:

- **A (Address):** Traduce un nombre de dominio a una dirección IPv4.
- **AAAA (IPv6 Address):** Similar al registro A, pero para direcciones IPv6.
- **MX (Mail Exchange):** Especifica los servidores encargados de la recepción de correos.
- **TXT (Text):** Permite insertar texto libre. Se usa para seguridad (SPF, DKIM) y validación de propiedad.
- **CNAME (Canonical Name):** Un alias que apunta un nombre a otro nombre (ej. `www` a `repsol.com`).
- **NS (Name Server):** Identifica los servidores que tienen la autoridad DNS de la zona.
- **SOA (Start of Authority):** Contiene información sobre la administración de la zona DNS (seriales, tiempos de expiración).
- **PTR (Pointer):** Se usa para la resolución inversa (de IP a nombre).

Reconocimiento Pasivo vs. Activo en DNS: Se considera pasivo cuando consultamos bases de datos que ya tienen la información (como DNSDumpster o ViewDNS) sin tocar los servidores de la víctima. Se vuelve activo cuando lanzamos consultas directas (usando `dig` o `nslookup`) a los servidores DNS de la empresa, ya que nuestra IP queda registrada en sus logs.

2. Perfilado de Repsol S.A.

Repsol es una de las mayores compañías energéticas del mundo.

- **Clientes:** Usuarios finales (estaciones de servicio), industrias químicas, aviación y clientes de luz/gas.
- **Proveedores:** Empresas de ingeniería, logística de crudo y servicios tecnológicos (Azure, AWS).
- **Servicios:** Refino, comercialización de energía renovable, gas natural y productos petroquímicos.

Resultados

Análisis de Infraestructura

Se han utilizado herramientas como DNSDumpster para mapear la superficie expuesta.

Tipo	Servidor Identificado	Implicación

MX	repsol-com.mail.protection.outlook.com	Filtrado de correo gestionado por Microsoft.
Infraestructura	Múltiples subdominios en Azure	Centralización de servicios en la nube.

Host	IP	ASN	ASN Name	Open Services (from DB)	RevIP
repsol-com.mail.protection.outlook.com	52.101.68.10 mail-dbbpr03cu00102.inbound.protection.outlook.com	ASN 8075 52.96.0.0/12	MICROSOFT-CORP-MSN-AS-BLOCK - Microsoft Corporation Ireland		56495
repsol-com.mail.protection.outlook.com	52.101.68.32	ASN 8075 52.96.0.0/12	MICROSOFT-CORP-MSN-AS-BLOCK - Microsoft Corporation Ireland		56301
repsol-com.mail.protection.outlook.com	52.101.73.24 mail-asdpr05cu00308.inbound.protection.outlook.com	ASN 8075 52.96.0.0/12	MICROSOFT-CORP-MSN-AS-BLOCK - Microsoft Corporation The Netherlands		56870
repsol-com.mail.protection.outlook.com	52.101.73.28 mail-am7pr05cu00204.inbound.protection.outlook.com	ASN 8075 52.96.0.0/12	MICROSOFT-CORP-MSN-AS-BLOCK - Microsoft Corporation The Netherlands		56358

Figura 1: Registros MX identificados para el dominio repsol.com.

Google Dorking (Fuga de Información)

Se han ejecutado tres estrategias de búsqueda avanzada para localizar datos sensibles:

Dork	Resultado Esperado
`site:repsol.com filetype:pdf "confidencial"`	Documentos internos con marcado de sensibilidad.
`site:repsol.com inurl:login`	Paneles de acceso para empleados o colaboradores.
`site:repsol.com intitle:"index of"`	Listado de directorios sin protección de servidor.

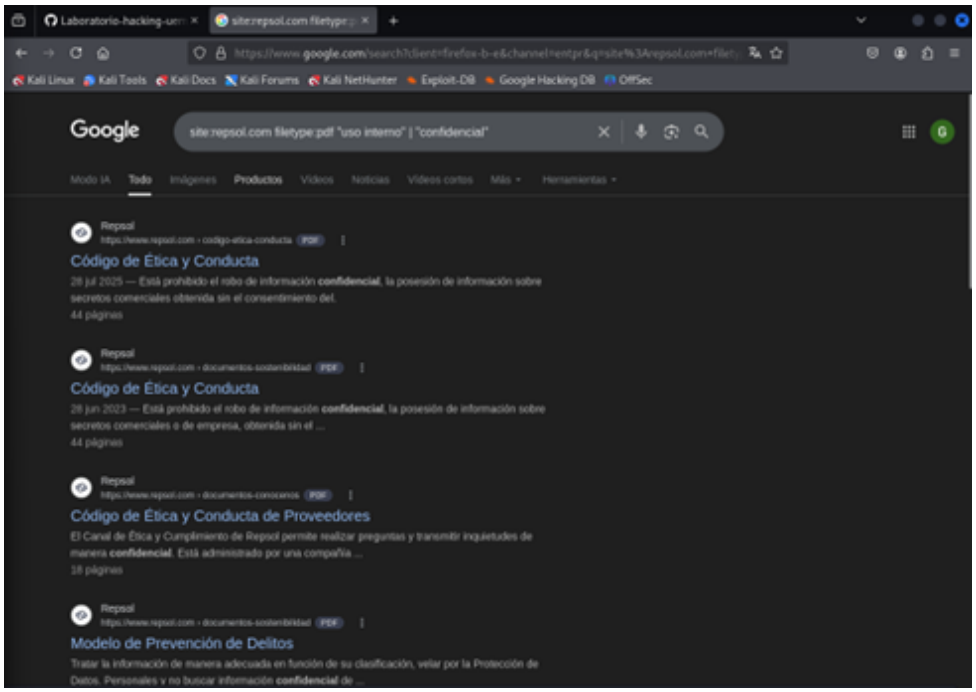

Figura 2: Dork 1: Localización de archivos PDF sensibles.

Figura 3: Grafo de relaciones entre subdominios (Footprinting).

Conclusiones

Repsol presenta una superficie de exposición amplia debido a su tamaño. El uso de infraestructuras de terceros (Microsoft Office 365) es evidente en sus registros MX, lo que traslada parte de la seguridad a la nube. Los dorks han permitido hallar documentos que, aunque públicos, contienen información de uso interno que podría ser usada en ingeniería social.

Bibliografía